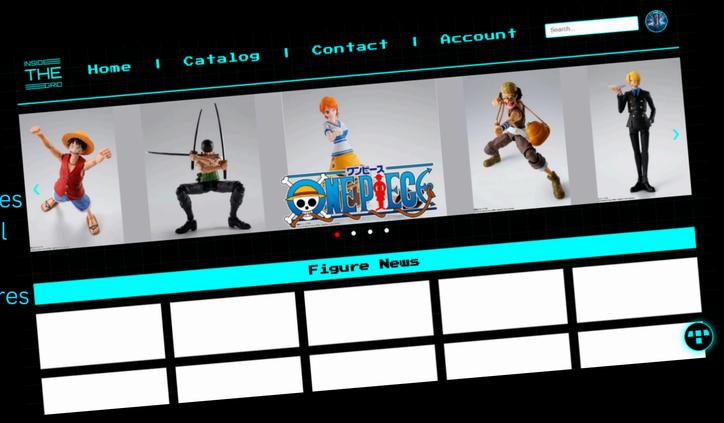
An Investigation on How to Analyze Design, Implement, Test and Evaluate a GDPR Compliant, Role-Based Secure Web Application

By Dan Ferguson

Summary

This project focuses on the design and development of a secure web application that demonstrates how user data can be protected using modern security principles according to GDPR regulations. The system incorporates role-based access control (RBAC) to manage user permissions, ensuring that access to features and data is restricted based on user roles. To enhance security, the application includes features such as two-factor authentication, password management, and protection against common vulnerabilities like SQL injection.



Results

The final prototype successfully demonstrates a secure web application with multiple implemented features. These include user authentication with two-factor verification, role-based access control to restrict system functionality, and protection against common vulnerabilities such as SQL injection. Additional functionality allows users to manage personal figure collections and organise them into subcollections. An administrative interface was also developed to manage roles and permissions. Testing confirmed that the system behaves reliably and prevents unauthorised access.

Introduction

Modern web applications store and process large amounts of sensitive user data, making security a critical concern. Vulnerabilities such as weak authentication or poor access control can lead to data breaches and unauthorised access. Regulations like the General Data Protection Regulation (GDPR) require organisations to handle user data securely. This project explores how secure design principles and role-based access control (RBAC) can be implemented to improve web application security.

Conclusion

The project successfully demonstrates how secure development practices can be applied within a web application. The implementation of RBAC, authentication mechanisms, and secure database interaction shows that user data and system functionality can be effectively protected. While the system does not fully meet all modern security and GDPR standards, it provides a strong foundation and highlights the importance of integrating security throughout the development lifecycle.

Methodology

The system was developed using an iterative prototyping approach, progressing from an initial functional prototype to a more secure and feature-rich version. The application was built using the Flask web framework, with MySQL used as the database and SQLAlchemy as the Object Relational Mapper to ensure secure, parameterised queries. Key security features, including two-factor authentication, password management, and role-based access control, were integrated into the system design. Testing was carried out using structured test cases to validate both functionality and security.

Further Work

There are several opportunities to further develop the system. Security could be enhanced through stronger two-factor authentication methods, such as authenticator apps, and more comprehensive logging. Additional GDPR features, including data export and account deletion, could be implemented to improve compliance. The user interface could also be refined to improve usability and accessibility. A key future extension is the addition of social features, allowing users to share collections, create posts, and communicate with others, although this would introduce new security and moderation challenges.